

Risicoanalysedocument portfoliowebste

Versie 1.1

10 februari 2026

Opdrachtgever: Windesheim

Uitvoerende partij: Naweed Noori s1200179

Versiebeheer

Versie	Datum	Wijzigingen	Auteur
1.0	23-08-2025	Eerste opzet	Karen
1.1	10-02-2026	Methodiek en risicomatrix aanpassen, zodat deze aansluit op de introductieles van security.	John en Karen

Inhoud

Versiebeheer	2
1 Inleiding.....	4
1.1 Over de portfoliowebsite	4
1.2 De opdracht.....	4
2 Managementsamenvatting	5
3 Scope	5
4 Analyseaanpak	5
5 Methodiek	5
6 Risicomatrix	6
7 Advies aan de opdrachtgever	8
7.1 Roadmap.....	9
8 Bijlage: requirements	9

1 Inleiding

1.1 Over de portfoliowebsite

De portfoliowebsite is jouw persoonlijke website. Als je later in je studie stage gaat lopen of op zoek gaat naar een baan, dan kan het handig zijn om een online visitekaartje (profielpagina) te hebben, zodat bedrijven kunnen zien wat jij te bieden hebt. In de huidige situatie kunnen organisaties die op zoek zijn naar een software engineer zich inmiddels een beeld vormen van jouw vaardigheden. De profielpagina heb je namelijk gerealiseerd in sprint 1. In deze sprint moet er een nieuwe pagina ontwikkeld worden: de contactpagina. Het doel daarvan is dat organisaties na zich te hebben georiënteerd ook contact kunnen opnemen met je.

1.2 De opdracht

Er is al een werkende contactpagina gerealiseerd (zie git). Je werkt voor dus niet verder in je codebase van vorige sprint, maar in een nieuwe codebase. In deze codebase zijn echter een aantal issues te vinden op gebied van toegankelijkheid en beveiliging. Pas de in de theorieweek opgedane kennis toe door te achterhalen welke risico's er zijn. Maak de risico's inzichtelijk door de risicomatrix in dit document in te vullen.

Nadat je de risico's geïnventariseerd en geprioriteerd hebt, schrijf je een advies van maximaal één A4 aan de opdrachtgever waarin je aangeeft wat er moet gebeuren en binnen welke termijn. Ga er bij het schrijven van je advies vanuit dat de opdrachtgever beperkt technisch onderlegd is. Wees dus concreet en duidelijk, zonder teveel in de technische details te duiken.

2 Managementsamenvatting

In dit risicoanalyse document is de contactpagina van de portfoliowebsite onderzocht op risico's rondom gebruikersinvoer, met focus op toegankelijkheid (WCAG 2.1 AA) en basale beveiliging/robustheid. Op basis van requirements, code-review en praktijktests (o.a. DevTools/Lighthouse, toetsenbordnavigatie en Windows Verteller) zijn negen risico's geïdentificeerd en geprioriteerd met een vereenvoudigde OWASP risk-rating. De grootste risico's zijn Kritiek: (1) XSS door onveilige weergave van invoer op de bedankpagina (RSK1) en (2) het niet kunnen bedienen van het formulier met toetsenbord door geblokkeerde Tab-navigatie en onzichtbare focus (RSK7). Daarnaast zijn er meerdere Hoge risico's, zoals DOM-XSS in client-side foutmeldingen (RSK2), ontbreken van server-side validatie en betrouwbare foutafhandeling (RSK3/RSK4), onvoldoende spam-maatregelen (RSK6) en onjuiste semantiek/labels en contrastproblemen (RSK8/RSK9). Het advies is om te kiezen voor een robuuste aanpak (alternatief B): server-side validatie en veilige output als basis, aangevuld met WCAG-verbeteringen en anti-misbruikmaatregelen (CSRF + server-side honeypot). Dit borgt met name FR04 (foutmelding + invoer behouden), FR03 (duidelijke bevestiging) en NFR01/NFR02 (WCAG + intuïtieve bediening). In de roadmap worden eerst de meest impactvolle en relatief eenvoudig op te lossen issues ("laaghangend fruit") aangepakt: in fase 0 (0–24 uur) RSK1, RSK3 en RSK7; daarna volgen in fase 1 de resterende hoge risico's (RSK2, RSK5, RSK6, RSK8) en in fase 2 de finetuning van foutafhandeling en contrast/WCAG her-test (RSK4, RSK9).

3 Scope

Binnen de scope van de opdracht: de contactpagina en bijbehorende server-side logica, e-mailafhandeling, client-side scripts en basisconfiguratie. Buiten de scope van de opdracht: externe infrastructuur (mailprovider), logging/monitoring buiten de applicatie, penetratietesten van derden.

4 Analyseaanpak

Om efficiënt en effectief tot een volledige risicolijst te komen, wordt de contactpagina onderzocht met requirements als checklist en code-review van views/controllers/JS/CSS, waarna de bevindingen worden gevalideerd met scenario's (happy flow, expected unhappy flows en misbruikflows). Voor toegankelijkheid worden Chrome DevTools/Lighthouse, toetsenbordtests (Tab/Shift+Tab, zichtbare focus) en Windows Verteller (Narrator) gebruikt, plus een selectie WCAG 2.1 AA succescriteria voor formulieren (labels, foutmeldingen, focus, contrast). Voor security/robustheid worden DevTools Network/Console gebruikt om POST-gedrag en foutafhandeling te controleren en worden veilige testcases uitgevoerd (leeg/ongeldig, te lange invoer, onschuldige HTML-invoer, spam/honeypot). Tests worden uitgevoerd op desktop én responsive/mobile (Device Toolbar). Kans/impact wordt vervolgens consistent vastgelegd met het risicobeoordelingsbestand en geprioriteerd met OWASP-risk-rating, zodat duidelijk is welke maatregelen eerst nodig zijn.

5 Methodiek

Voor het classificeren en prioriteren van risico's wordt de OWASP Risk Rating Methodology gebruikt in een vereenvoudigde vorm. Per risico worden kans (likelijkheid) en impact ingedeeld als Laag / Gemiddeld / Hoog. Kans wordt bepaald op basis van (1) hoe zichtbaar het probleem is in de code/UI en (2) hoe eenvoudig het is om het uit te buiten (bijv. zonder speciale tools of rechten). Impact wordt bepaald op basis van (1) effect op de gebruiker en de applicatie (veiligheid/robustheid) en (2) mate waarin requirements worden geschonden (FR01–FR04 en NFR01–NFR03). De risicoscore volgt uit de combinatie van kans en impact volgens deze matrix:

Risicobepaling		
Impact	Kans	Risico
Laag	Laag	Notitie
Laag	Gemiddeld	Laag
Laag	Hoog	Gemiddeld
Gemiddeld	Laag	Laag
Gemiddeld	Gemiddeld	Gemiddeld
Gemiddeld	Hoog	Hoog
Hoog	Laag	Gemiddeld
Hoog	Gemiddeld	Hoog
Hoog	Hoog	Kritiek

Deze aanpak maakt de prioritering navolgbaar en koppelt risico's direct aan de context van toegankelijkheid (WCAG 2.1 AA) en beveiliging.

6 Risicomatrix

ID	Beschrijving	Relevantecodebestand	Kans	Impact	Risico	Onderbouwing
RSK1	XSS via onveilige weergave van gebruikersinvoer op de bedanktpagina (script/HTML kan worden uitgevoerd). (NFR01)	Views/Thanks.cshtml	Hoog	Hoog	Kritiek	Invoer wordt met Html.Raw gerenderd, waardoor HTML/script niet wordt ge-escaped en eenvoudig te misbruiken is. Dit kan leiden tot het uitvoeren van scripts in de browser van de gebruiker (veiligheidsimpact hoog).
RSK2	DOM XSS doordat client-side foutmeldingen gebruikersinvoer via innerHTML tonen. (NFR01)	Wwwroot/js/site.js	Gemiddeld	Hoog	Hoog	De foutmelding plaatst direct ingevoerde tekst in innerHTML, waardoor kwaadaardige HTML kan "meekomen". Dit is relatief eenvoudig te triggeren en heeft hoge impact omdat het in de browser wordt uitgevoerd.
RSK3	Geen server-side validatie: formulier kan met lege/ongeldige velden worden verstuurd, wat leidt tot fouten en slechte feedback. (FR04, NFR02)	Controllers/ContactController.cs, Views/Contact/Index.cshtml	Hoog	Gemiddeld	Hoog	De server accepteert alle warden zonder ModelState-controle, waardoor expected unhappy flows niet netjes worden afgehandeld. Dit schendt FR04 (melding + invoer behouden) en levert instabiel gedrag op.
RSK4	Onvriendelijke foutafhandeling informatiek bij e-mail falen (exception), waardoor de flow breekt. (FR04)	Controllers/ContactController.cs, Services/SmtpEmailSender.cs	Gemiddeld	Gemiddeld	Gemiddeld	Als SMTP faalt wordt geen fout opgevangen, waardoor de gebruiker geen nette melding krijgt en de inzending niet wordt verwerkt. Dit schendt FR04 en maakt de applicatie minder robuust.

RSK5	CSRF-risico: token staat in form, maar POST valideert niet afgedwongen (geen [ValidateAntiForgeryToken]). (Beveiliging)	Controllers/ContactController.cs, Views/Contact/Index.cshtml	Gemiddeld	Gemiddeld	Gemiddeld	Zonder server-side tokenvalidatie kan een externe site een POST proberen uit te voeren namens de gebruiker. Dit verhoogt misbruik/spam-kans en raakt de betrouwbaarheid van de inzending.
RSK6	Spambeveiliging alleen client-side (honeypot-check in JS) en daardoor eenvoudig te omzeilen met directe POST. (FR02/FR04, robuustheid)	wwwroot/js/site.js, Views/Contact/Index.cshtml	Hoog	Gemiddeld	Hoog	Bots kunnen JavaScript omzeilen en direct het formulier posten, waardoor de huidige spamcheck niet werkt. Dit kan leiden tot veel ongewenste berichten en verstoring van de contactfunctie.
RSK7	Toetsenbordbediening faalt (Tab geblokkeerd, focus onzichtbaar, tabindex=-1) WCAG fail. (NFR01, NFR02)	Wwwroot/js/site.js, wwwroot/css/site.css Views/Contact/Index.cshtml	Hoog	Hoog	Kritiek	Tab-navigatie wordt bewust geblokkeerd en focus wordt visueel verwijderd, waardoor keyboard-users het formulier niet kunnen bedienen. Dit schendt WCAG 2.1 AA en tast de bruikbaarheid direct aan.
RSK8	Labels/semantiek niet correct gekoppeld (label-for mismatch, aria-hidden label, div als button). (NFR01)	Views/Index.cshtml, Views/Contact/Thanks.cshtml	Hoog	Gemiddeld	Hoog	Screenreaders en assistive tech kunnen velden/acties minder goed begrijpen door verkeerde koppelingen en niet-semantische knoppen. Dit maakt het formulier minder toegankelijk en kan inzendingen verhinderen.
RSK9	Contrast/leesbaarheid onvoldoende (lichte tekst/knop) WCAG-contrast fail. (NFR01)	wwwroot/css/site.css	Hoog	Gemiddeld	Hoog	De gekozen kleuren (lichte grijs tinten) leveren te laag contrast op, waardoor tekst/knoppen slecht leesbaar zijn. Dit heeft directe impact op toegankelijkheid (WCAG 2.1 AA).

7 Advies aan de opdrachtgever

Probleemstelling

De contactpagina verwerkt gebruikersinvoer niet betrouwbaar genoeg, waardoor er risico's zijn voor toegankelijkheid (toetsenbord/screenreader/leesbaarheid) en beveiliging/robustheid (spam, onveilige weergave van invoer, fouten zonder duidelijke melding). Dit kan ervoor zorgen dat contact opnemen faalt en dat de pagina misbruikt wordt.

Alternatieven

A: Alleen quick fixes in het front-end (HTML/CSS/JS) om vooral zichtbare WCAG-problemen te verminderen.

B: Robuuste aanpak: server-side validatie + veilige output + CSRF/spam-maatregelen, en daarnaast WCAG-verbeteringen in het formulier.

Vergelijking

- Toegankelijkheid: A verbetert een deel, maar blijft kwetsbaar bij afwijkend gedrag/zonder JS; B borgt consistente foutfeedback en bediening (beter voor WCAG).
- Beveiliging/robustheid: A is makkelijker te omzeilen (bots/direct POST); B verlaagt risico's structureel doordat controles server-side worden afgedwongen.
- Impact vs effort "laaghangend fruit": B pakt met enkele gerichte wijzigingen meerdere hoge risico's tegelijk aan (bijv. XSS, validatie, foutafhandeling).

Keuze, Onderbouwing en Advies

Advies is alternatief B, omdat dit de grootste risico's uit de risicomatrix met de meeste impact reduceert en het beste aansluit op de requirements (FR04 foutmeldingen + invoer behouden, NFR01 WCAG 2.1 AA), zonder onnodige technische complexiteit voor de gebruiker.

Vervolgstappen

- Validatie en outputcontrole: De eerste prioriteit ligt bij het realiseren van een veilige weergave en het implementeren van server-side validatie, aangevuld met heldere foutmeldingen voor de eindgebruiker.
- Toegankelijkheid (WCAG): Vervolgens wordt de applicatie geoptimaliseerd volgens de WCAG-normen. Hierbij ligt de focus specifiek op het beheer van focus-elementen, labels, knoppen en het kleurcontrast.
- Beveiliging en verificatie: Het traject wordt afgerond met de implementatie van CSRF-bescherming en een server-side spamcheck. Ter afsluiting worden alle scenario's opnieuw integraal getest om de werking te verifiëren.

7.1 Roadmap

7.1.1 Fase 0 – Meteen (0–24 uur)

- RSK1 (XSS via Html.Raw op Thanks)
- RSK3 (geen server-side validatie / FR04)
- RSK7 (toetsenbord + focus werkt niet)

7.1.2 Fase 1 – Binnen 1 week

- RSK2 (DOM XSS via innerHTML)
- RSK5 (CSRF afdwingen)
- RSK6 (server-side spamcheck/honeypot)
- RSK8 (labels/semantiek + echte knoppen)

7.1.3 Fase 2 – Binnen 2–4 weken

- RSK4 (robuste foutafhandeling + e-mailconfig verbeteren)
- RSK9 (contrast/leesbaarheid finetunen + her-test WCAG)

8 Bijlage: requirements

Tabel 1

Functionele requirements van de contactpagina

Id	Beschrijving
FR01	Formulier bevat velden Naam, E-mail, Onderwerp, Bericht
FR02	Bericht wordt per e-mail doorgestuurd naar een configureerbare ontvanger
FR03	Na succesvolle verzending ziet de gebruiker een duidelijke bevestiging
FR04	Bij fouten krijgt de gebruiker een melding en blijft de invoer behouden

Tabel 2

Niet-functionele requirements van de contactpagina

Id	Beschrijving
NFR01	Toegankelijkheid: voldoet aan WCAG 2.1 AA
NFR02	Gebruikservaring: responsief (mobiel/desktop) en intuïtief te bedienen
NFR03	Compatibiliteit: ondersteunt recente versies van moderne browsers